GRC

RISK AND CONTROL ADVISORY

Q1 2027 progress report

2027 Security NFR Controls Testing Plan — Tier 1 & Tier 2 ICT assets

PREPARED FOR

2LoD CISO Office (ICT risk control function)

CONFIDENTIAL PLAN V1

REFERENCE AP-2027-001-Q1	ENGAGEMENT AP-2027-001 2027 Security NFR Controls Testing Plan — Tier 1 & Tier 2 ICT assets	VERSION Plan v1
PREPARED BY PM (2LoD)	REVIEWED BY CISO (2LoD)	REPORT DATE 2027-04-30
ASSESSMENT PERIOD 1 Jan – 31 Mar 2027	FRAMEWORKS DORA Art. 6(4), 6(5), 8(1), 24(6), RTS (EU) 2024/1774 Art. 2(2)(c), 4–5, 27	DISTRIBUTION ICT Risk Committee

Executive Summary

This is the Q1 progress report on AP-2027-001, 2027 Security NFR Controls Testing Plan — Tier 1 & Tier 2 ICT assets, to the ICT Risk Committee. It covers 1 Jan – 31 Mar 2027 and reflects the plan's records on 12 Apr 2027.

2LoD planned 19 test(s) for Q1, drew 17 item(s), opened 17 test(s), completed fieldwork on 15 and signed off 15. 1 attribute fail(s) were recorded.

1 finding(s) were raised in Audit Findings from Q1's fails; they are set out below as that module holds them.

FINDINGS BY SEVERITY

0	1	0	0	0
CRITICAL	HIGH	MEDIUM	LOW	INFO

KEY MESSAGES

- Tier 1: 25 of 80 items attested by 31 Mar 2027, 31.25% against a plan of 35% (Amber).
- Tier 2: 32 of 240 items attested by 31 Mar 2027, 13.33% against a plan of 15% (Amber).
- Q1 testing: 17 of 19 planned tests opened, 15 signed off by QA, 1 attribute fail(s).

Contents

Executive Summary 2
1 Coverage against plan 4
2 Testing in Q1 4
3 Deviations so far this year 5
4 Resourcing 5
5 Next quarter 5
6 Findings 6
6.1 AF-2026-001 NFR-04 Access management & recertification not met on T1-022 Example Card authorisation 02 6
A Test attributes 7
Limitations and Basis of Reporting 7

1 Coverage against plan

1LoD owners attest their items in quarterly waves, and 2LoD reviews the data quality of every submission. An item counts as covered on its attestation date. The plan sets a cumulative target for each stratum at each quarter end; the RAG compares it with the share attested by that date: Green on or above plan, Amber within 10 points below, Red further below, Not due before the quarter ends. Attested and DQ accepted count the items dated on or before the quarter end.

COVERAGE AT THE END OF Q1

Stratum	N	Target	Attested	Share	RAG	DQ accepted
Tier 1	80	35%	25	31.25%	Amber	25
Tier 2	240	15%	32	13.33%	Amber	32

2 Testing in Q1

2LoD planned 19 test(s) for Q1, drew 17 item(s), opened 17 test(s), completed fieldwork on 15 and signed off 15. 1 attribute fail(s) were recorded. A test's result is Effective with no fails, Partially effective from 1 and Ineffective from 3; a result not yet signed off by QA is provisional.

Q1 TESTS

Test	Item	Name	Stratum	Result	Fails	QA signed off
T27-Q1-001	T1-022	Example Card authorisation 02	T1	Partially effective	1	9 Apr 2027
T27-Q1-002	T1-018	Example Contact centre 01	T1	Effective	0	9 Apr 2027
T27-Q1-003	T1-009	Example Fraud monitoring 01	T1	Effective	0	9 Apr 2027
T27-Q1-004	T1-013	Example HR and payroll 01	T1	Effective	0	9 Apr 2027
T27-Q1-005	T1-002	Example Card authorisation 01	T1	Effective	0	9 Apr 2027
T27-Q1-006	T1-007	Example Identity provider 01	T1	Effective	0	9 Apr 2027
T27-Q1-007	T1-020	Example Payments gateway 02	T1	Effective	0	9 Apr 2027
T27-Q1-008	T1-016	Example AML screening 01	T1	Effective	0	9 Apr 2027
T27-Q1-009	T1-027	Example Identity provider 02	T1	Effective	0	9 Apr 2027
T27-Q1-010	T1-025	Example Treasury dealing 02	T1	Effective	0	9 Apr 2027
T27-Q1-011	T1-001	Example Core banking ledger 01	T1	Effective	0	9 Apr 2027
T27-Q1-012	T1-024	Example Mobile banking API 02	T1	Effective	0	9 Apr 2027
T27-Q1-013	T1-026	Example Customer data hub 02	T1	Effective	0	9 Apr 2027
T27-Q1-014	T2-006	Example Customer data hub 05	T2	Effective	0	9 Apr 2027

T27-Q1-015	T2-031	Example General ledger 06	T2	Effective	0	9 Apr 2027
T27-Q1-016	T2-024	Example Mobile banking API 06	T2	Not started	0	Awaiting
T27-Q1-017	T2-009	Example Fraud monitoring 05	T2	Not started	0	Awaiting

3 Deviations so far this year

The deviation rule is cumulative for the year, per attribute and stratum. Only attributes with a deviation are listed.

Attribute	Stratum	Tested	Deviations	Conclusion	Next step
NFR-04	T1	13	1	1 deviation – extend sample	+7 test(s) in Q2

4 Resourcing

The plan budgets 74.4 person-days for Q1 against a capacity of 100 (74.4%, threshold 85%).

5 Next quarter

Q2: the 1LoD wave is due by 28 May 2027, the sample is drawn on 31 May 2027, fieldwork runs 7 Jun – 9 Jul 2027 and the report is due on 30 Jul 2027.

6 Findings

Ref	Finding	Severity	Control
AF-2026-001	NFR-04 Access management & recertification not met on T1-022 Example Card authorisation 02	HIGH	AC-2, AC-6

6.1 AF-2026-001 NFR-04 Access management & recertification not met on T1-022 Example Card authorisation 02

HIGH AC-2, AC-6 OPEN

OBSERVATION

Evidence received and walked through with the asset owner.

note on NFR-04

A Test attributes

What 2LoD tested on every selected item. The full requirement, procedure, evidence and pass criteria are in the plan's export.

Ref	Domain	Method	800-53
NFR-01	Asset identification & classification	Inspection	CM-8, RA-2
NFR-02	Security requirements specified & approved	Inspection	SA-4, PL-2
NFR-03	Identity & authentication	Inspection	IA-2, IA-5
NFR-04	Access management & recertification	Re-performance	AC-2, AC-6
NFR-05	Privileged access	Inspection	AC-2, AC-6
NFR-06	Encryption at rest & key management	Inspection	SC-28, SC-12
NFR-07	Encryption in transit	Inspection	SC-8, SC-13
NFR-08	Logging & security monitoring	Inspection	AU-2, AU-6, SI-4
NFR-09	Vulnerability & patch management	Inspection	RA-5, SI-2
NFR-10	Secure configuration & hardening	Inspection	CM-6, CM-7
NFR-11	Network security & exposure	Inspection	SC-7
NFR-12	Security testing ≤ 12 months	Inspection	CA-8, SA-11
NFR-13	Backup, recovery & RTO/RPO	Inspection	CP-9, CP-10, CP-4
NFR-14	Change management	Inspection	CM-3, CM-4
NFR-15	Third-party, legacy & end-of-support	Inspection	SA-22, SA-9
NFR-16	Exceptions & risk acceptance	Inspection	CA-5, RA-7

Limitations and Basis of Reporting

This report is prepared by the 2LoD CISO Office (ICT risk control function) for the ICT Risk Committee, from the records of assurance plan AP-2027-001 as they stood on 12 Apr 2027. It does not reflect changes made after that date. Coverage is measured from the attestation and data-quality review dates recorded in the plan. Testing is on samples, which gives reasonable rather than absolute assurance. Results not signed off by QA are provisional. Findings are reported as Audit Findings holds them on the report date; their remediation is followed up there.